Product finalization review - 30 October 2026

Result

The local regression suite passes: 213 tests (34 client, 179 server), zero failures, one intentionally skipped duplicate S3 case. The production build and TypeScript checks pass. ESLint reports zero errors and six pre-existing warnings. npm audit reports zero known vulnerabilities in both dependency trees at the time checked.

This is a verified local improvement pass, not a statement that every bug has been found or that production is ready. PostgreSQL on the existing VPS is the selected deployment direction; the owner requested setup instructions only. No VPS connection, production database mutation, real guest notification, deployment or account cutover occurred.

New findings, source and fixes

F01 - High, malformed password hashes could accept an incorrect password

Source: usersStore-file.js passwordMatches, also imported by the PostgreSQL adapter. Node’s hex decoder silently truncated invalid hex; a value such as zz:zz produced a zero-length expected/derived key and a successful empty comparison. This requires malformed stored account data, not merely a wrong password against a valid hash. Fix: validate the exact existing 16-byte salt / 64-byte key format before scrypt; use a fixed derivation size. Shared accountCredentials.js removes the PostgreSQL adapter’s dependency on the file persistence implementation. Verification: malformed/short/null hashes fail, valid credentials pass, incorrect credentials fail; full API account suite passes.

F02 - Medium, database URL TLS settings could replace the configured CA

Source: db.js combined connectionString and ssl without handling pg’s documented precedence. Fix: dbConfig.js rejects conflicting URL SSL parameters when DATABASE_CA_FILE is present and explicitly verifies certificates. Verification: configuration conflict tests; real TLS handshake still requires the VPS/test database.

F03 - Medium, database connection and statement waits were unbounded by application configuration

Source: db.js pool configuration had only pool size. Fix: bounded connection acquisition, statement and idle-transaction timeouts; validate positive integer limits and pool size. Verification: configuration tests and real pg.Client construction. Database outage/load behavior remains unverified without a running database.

F04 - Medium, simultaneous migration runners could race schema creation/application

Source: db.js created schema/migration ledger before any cross-process lock. Fix: transaction-scoped advisory lock before schema creation; migration ledger and DDL commit together. Account bootstrap/admin/import operations also share their own advisory lock. Verification: source review, JavaScript syntax and existing suite; the new test:postgres drill exercises real concurrent migrations/admin changes when connected. Do not mark real PostgreSQL concurrency verified yet.

F05 - High, account import could silently mismatch identities or leave a partial migration

Source: scripts/import-users.js inserted one account at a time and ignored email conflicts. A database account with the same email but a different ID could be retained while project ownership still referenced the old file ID. A later error could leave earlier inserts committed. Reset-link state was also omitted, and source directory failures were treated as an empty successful import. Fix: one transaction, shared bootstrap lock, explicit ID/email conflict rejection, preserve reset state, fail on missing/unreadable/empty source, close the pool in finally. Verification: conflict/identity/reset preservation unit tests. Real SQL rollback drill is prepared but not run.

F06 - Medium, manual room blocks could exceed the inventory calculation horizon

Source: routes/reservations.js validated interval length with nightsOf, which intentionally stops at 366 entries. Thus a multi-year interval passed the <=366 check while later nights were omitted from occupancy. Fix: validate the full calendar difference before using the bounded iterator. Verification: API rejects a 731-night block without writing inventory and accepts the 366-night boundary.

F07 - Medium, early room search used the table booking timezone

Source: StaySearch used /clock, which always returned site.booking.timezone although rooms have their own stays.timezone. Around midnight this could reject a valid room arrival date. Fix: typed optional stay clock request and room-specific server timezone. Verification: independent Honolulu room/Kathmandu table configuration returns the expected room clock; existing tour clock behavior retained.

F08 - Medium, project/inbox pending counts could use the wrong day

Source: properties.waitingOn hardcoded Kathmandu; the reservation inbox preferred disabled table defaults over enabled room settings. Project home also included room requests on their checkout day. Fix: shared enabled-service timezone selection for inbox/project summaries and exclusive checkout comparisons in both project count paths. Verification: enabled-service timezone tests and full API/client suite. One summary day is still used for a venue; configurations spanning genuinely different timezones within one project require separate per-service UX.

F09 - Medium, additional environment filenames were not ignored

Source: .gitignore covered .env/.env.local but not general .env.production-style files. Fix: ignore .env.* while retaining .env.example templates. Verification: git check-ignore for backend/frontend production secret paths and example exclusions. This does not erase any previously committed secrets or replace credential rotation if a secret was exposed.

F10 - Low, PostgreSQL reset invalidation timestamp preceded password hashing

Source: usersStore-pg.resetPassword captured the cutoff before awaiting scrypt, unlike the file implementation. A session issued during hashing could fall after that cutoff. Fix: derive first, then capture the application timestamp used by the update. Verification: source review and account API regressions; the real PostgreSQL adapter still needs execution. Existing session design uses application clocks; cross-machine clock synchronization remains operationally important.

Refinements

DATABASE_PASSWORD can now hold a raw password separately from a password-free DATABASE_URL. Ambiguous double configuration is rejected. The actual pg parser is tested with reserved password characters. Backup and API configuration share URL/password construction. Real secrets were not generated into examples or copied into browser configuration.

The PostgreSQL setup/cutover guide is deploy/POSTGRESQL.md. It covers a dedicated role/database, local-only listening, PC-to-VPS SSH tunneling, private environment settings, disposable verification, transactional account import, backup/restore, and rollback limits. There is no new runtime dependency and no broad framework rewrite.

Browser verification

Current desktop (1440px) and mobile (390px) reservation fixtures passed phone search, overnight-calendar counting, checkout exclusion, selected-day/range filtering, waitlist and clearing filters, with no horizontal overflow. The fixture intercepts API responses; it never changes live guest data.

The local Chyasal client website passed sampled desktop/mobile rendering: no horizontal overflow, no broken loaded images, no captured uncaught runtime exceptions, and booking tabs clear the fixed header. Poppins headings and original system body text remain. Headless sample checks do not certify all customer content, screen readers, touch hardware, GPU behavior or animation performance.

The read-only client browser helper wrote its complete results but did not exit during cleanup; its identified Node process was stopped separately. The reservation fixture exited successfully. Treat the client evidence as completed browser observations, not a clean harness-exit result.

Earlier evidence remains available for the 195 design/font/viewport combinations, keyboard booking tabs, motion controls, draft recovery and review dialog. Those historical results are not represented as a fresh full rerun in this pass.

Launch requirements still open

1. Run the disposable PostgreSQL drill, actual account import and restore verification on the chosen VPS environment. Owner requested instructions only in this pass.

2. Keep one API process while projects/scenes/sites/reservations remain file-backed. Full transactional PostgreSQL migration, unified inventory, durable notification delivery and multi-process/load tests remain necessary before claiming large-platform scaling readiness.

3. Configure and verify HTTPS/domain/nginx/firewall, persistent directories, strong secrets, restart/recovery, disk monitoring and off-VPS backups. A successful local build does not test these.

4. Verify actual email/SMS/WhatsApp/AI/hotel-engine credentials, sender domains/templates and failure behavior. Tests use fake services. Notification work is not a durable delivery queue and can be lost on a process crash.

5. Validate every real venue’s room units, capacities, prices, timezones, floor-plan mapping, media and booking/deposit policy. Do not invent these business facts.

6. Complete real-device/GPU/mobile/low-bandwidth and accessibility checks, all studio-control workflows, and a realistic concurrency/volume test. No measured traffic capacity is claimed.

7. Resolve owner-content/policy placeholders and decide the intended behavior of the separate static GitHub Pages copy, whose interactive features require the API.

Evidence and reproducibility

Run npm test, npm run lint, npx tsc --noEmit and npm run build. Build in this session used NEXT_DIST_DIR=.next-new to avoid replacing the existing dev output. Logs: evidence/finalization-tests.log, finalization-types.log, finalization-lint.log, finalization-build.log, finalization-dependencies.json and finalization-server-dependencies.json. Browser logs have the finalization-browser prefix.

Feature inventory: feature-inventory.md. Exact test and API indexes: evidence/feature-test-index.txt and evidence/feature-route-index.txt. New regressions: server/test/finalization.test.js and additions to server/test/vps-regressions.test.js. Optional real PostgreSQL drill: cd server then npm run test:postgres, with a private TEST_DATABASE_URL to an empty dedicated *_test database.

The previous 30-finding audit is retained in report-previous-fix-status.md/pdf and findings.json. The current PDF includes that issue register plus this review and the feature inventory. Known issues are not erased by a newer report. Keep the audit artifacts private.

Technical references for database settings: https://node-postgres.com/features/ssl and https://node-postgres.com/apis/client. PostgreSQL environment-secret limitations: https://www.postgresql.org/docs/18/libpq-envars.html.

Product feature inventory and verification map

Reviewed 30 October 2026. This inventories the implemented capability groups, not every possible user input or device. Automated API tests use disposable data, fake mail/SMS/AI endpoints and local/fake-S3 assets. Passing them does not establish real provider delivery or production capacity. Exact test names and route definitions are in evidence/feature-test-index.txt and evidence/feature-route-index.txt.

Legend: A = automated behavior covered in the current passing suite; B = current browser check; H = earlier browser evidence retained; M = manual or infrastructure verification still needed. Coverage is partial within each broad group.

| Feature group | Implemented capabilities | Verification / remaining checks |

| Accounts | Personal sign-in, team-code signup, first-admin bootstrap, session cookies, logout, session refresh | A: auth/API suite; M: production HTTPS cookies and live login |

| Passwords | Scrypt hashing, forgot password, one-use reset link, password change, other-session invalidation | A: API/reset races/malformed hashes; M: real email and PostgreSQL execution |

| Team administration | List, promote/demote, last-admin guard, reset links, delete account | A: API; PostgreSQL concurrency drill prepared, not run |

| Project access | Owner/member visibility, sharing/removal, legacy claim, client staff permissions | A: ownership and role isolation API tests |

| Project lifecycle | Create, rename, delete/detach spaces, progress/delivered/archive status, feature flags | A: API; M: complete GUI lifecycle with representative customer projects |

| Branding | Name, logo upload, extracted accent, 10 current/3 legacy fonts, venue info and contact details | A: persistence/validation/color helpers; H: font isolation and 195 design/font/viewport combinations |

| Studio home | Project cards, waiting counts, activity, readiness information, links to editing/reporting | A: API/count rules; M: every dashboard state visually |

| Scene editing | Save/reload scene documents, revision conflicts, spawn, scale, transform, lighting/look settings | A: scene store/API; M: each control with real scans |

| History and recovery | Undo/redo, reload draft recovery, restore/download/discard recovered edits | A: recovery parser/revision guards; H: recovery fixture; M: all undo combinations and

crash scenarios |

| Camera authoring | Viewpoints, paths/tracks, waypoint positions, timings, narration/captions, preview playback | A: document persistence; M: complete GUI playback/recording and real audio |

| Placement and collision | Model transform, collision boxes, placement on scanned surfaces, floor detection, up-axis correction | A: client geometry/collision tests; M: every uploaded scan and GPU tier |

| Hotspots | Text, image, video, audio, URL, portal, table, room, hall; reveal distance, layout, localization, copying | A: layout, safe URLs, published references, booking routing; M: all interactive media/cards on touch devices |

| Upload pipeline | Chunked/resumable uploads, ownership, quota/expiry, finalize, archive extraction limits | A: API/local/fake S3, duplicate chunks, access and quota regressions |

| Model formats | LCC splats, converted GLB meshes/point clouds, 360 MP4, conversion worker | A: format/header checks, file serving, collision helpers; M: large real conversions and memory pressure |

| Media | Photos, thumbnails, floor-plan images, audio, private event documents, byte-range streaming | A: format/size/range/permission tests; M: all actual venue assets and playback |

| Publishing | Readiness warnings, immutable numbered snapshots, unpublish/republish, restore versions | A: API, monotonic history, ownership preservation; M: GUI publish checklist |

| Tour navigation | Start/loading screen, Walk/Fly/Orbit/Viewpoints, keyboard/touch controls, arrival transitions | A: relevant pure geometry; M: real GPU/mobile interaction and first-frame performance |

| Multi-space tours | Lazy scene loading, portals, day/night variants, building/floor groups, quality adaptation | A: grouping and quality rules, build/types; M: slow/failing model downloads and measured device performance |

| Tour floor map | Position indicator, floors/buildings, space navigation, generated/annotated plans | A: floor-plan extraction/mark persistence; M: map accuracy against real venue plans |

| Tour access and sharing | Embeds, allowed-host checks, key rotation, share metadata, QR codes, branded hub | A: embed authorization and safe host tests; M: real third-party iframe/fullscreen/share previews |

| Languages/accessibility | English/Nepali/Chinese strings, localized hotspots, reduced motion, no-WebGL enquiry fallback | A: translation completeness; H: keyboard booking tabs/motion; M: screen reader, contrast, touch and fallback audit |

| GUI website authoring | Sections, hero/story/facts, room descriptions, menu/outlets, gallery, reviews, FAQ, offers/contact | A: save/publish normalization and project isolation; M: each GUI field and extreme content |

| Website presentation | Five presets, brand fonts, light/dark, calm/expressive/no motion, guidance text, mobile spacing | A: presentation round trip; B: sample desktop/mobile; H: 195 combinations, no fresh full matrix in this pass |

| Website publication | Draft preview, publish, scheduled snapshot/cancel, private client review link/comments/approval | A: API isolation/scheduling/review; M: browser review collaboration and real scheduled wall-clock run |

| Website navigation | Mobile menu, room/space pages, chapter links, tour embed, booking tabs, primary CTAs | B: sample render, no overflow/broken loaded images/uncaught exceptions, booking header clearance; H: keyboard tabs |

| Early room search | Date/guest shortcut into existing room booking, venue date, stay length limits | A: room-clock regression; H: search-to-desk browser fixture |

| Table booking | Sitting hours/duration, capacity, table selection, any-table allocation, multiple dining outlets | A: availability, collisions, validation, outlet isolation; M: real business rules and live notifications |

| Room booking | Room types/units/capacity, nights, multi-room parties, checkout exclusivity, calendar/site plan | A: availability, overlap, capacity and request lifecycle; M: reconciled real inventory |

| Events | Halls, seated/standing capacity, day/evening/whole-day, event request and attachment | A: overlap/capacity/attachment retry/access; M: document viewing and approved venue policy |

| Hotspot bookings | Independent table/room/hall requests, mapped website resource links, external engine links | A: published-only checks, conflicts/channel guard, URL parameters; M: real engine contracts |

| Reservations inbox | Kind/status tabs, search/contact/reference, date range, list/month calendar, selected-day view | A: filter/calendar rules; B: desktop/mobile filter and calendar fixture |

| Reservation review | Open floor plan, see requested resource, availability recheck, confirm/decline, stale-status conflicts | A: authorization/conflicts/review API; H: review-dialog fixture; M: real guest receipt |

| Manual blocks | Staff room/hall/table blocks, availability subtraction, cancellation | A: API and >366-night rejection; M: reconciliation with external bookings |

| Waitlist | Room/table/event wait requests, notification when availability may return, delivery status | A: fake provider/API tests; M: real SMS/WhatsApp/email and restart durability |

| Enquiries | Tour/property/company forms, published scene validation, spam/rate limits, staff inbox and CSV | A: reference validation/access/export/fake mail; M: real recipient routing and delivery |

| Notifications | Email, SMS, WhatsApp, status outcomes, sender test, retry-friendly attachment behavior | A: provider mocks/phone normalization; M: sender DNS/templates/provider outages/durable retry queue |

| Analytics | Visits, dwell time, referrers/hotspots, enquiry counts, monthly reporting and print report | A: aggregation/API access; M: production traffic correctness and reporting at volume |

| AI tools | Published-information concierge, grounded navigation, studio translation/suggestions | A: mocked provider and context tests; M: real model quality, costs, quota and vendor failure behavior |

| Company website | Marketing/content routes, gallery, contact/planner/early access, FAQ, blog, account menu | A: shared form API; build routes; M: full marketing browser/content/link/policy review |

| SEO/discovery | Metadata, canonical URLs, robots, sitemap, RSS, llms.txt, public scene previews | Build/type checks; M: production canonical/domain, crawler and social-preview verification |

| Data integrity | Atomic file writes, mutation queues, corrupt-record handling, revision conflict rejection | A: read/write races, fail-closed bookings/sites, history, single writer |

| Storage and delivery | Local disk, S3-compatible storage, immutable assets, range requests, quotas/cleanup | A: fake S3/local storage, API and quota tests; M: real bucket permissions/cache/failures |

| PostgreSQL accounts | Pool, transactions, migrations, account adapter/import, environment credentials | A: config/driver parsing and import decisions; real SQL/concurrency/restore NOT run |

| Backups | JSON, external local assets, optional pg_dump, manifest, retention, optional bucket upload | A: local backup/restore; M: PostgreSQL restore, consistent stopped-writer backup and

off-VPS disaster drill |

| Operations/security | Production secret checks, loopback bind, single writer, rate limits, engine SSRF bounds | A: production startup, second-writer refusal, bounds/permissions; M: VPS firewall/TLS/nginx/monitoring/load |

Important boundaries

- Existing tests exercise many features, but there is no automated end-to-end test for every studio GUI control. This inventory explicitly records those gaps.

- Current file stores require one API writer. PostgreSQL account support is not a platform-wide database migration or a scaling certificate.

- Website and independent hotspot room/hall inventory are guarded against simultaneous use; unified physical inventory remains future work.

- Provider calls in tests are fake. No real guest messages, bookings or live configuration were changed during this pass.

- Fonts and client layouts remain GUI driven. This pass does not impose Inter on client sites or tours.

Previous audit issue register

A01 - Fixed: The shared signup code also grants unrestricted administrator access

Severity: High. Source: server/src/routes/auth.js:74.

Production refuses shared-password login and previously issued accountless JWTs. The uploader now signs in with a personal email/password. Development compatibility remains.

Acceptance check: The signup code alone must never authenticate as admin; deleted or demoted accounts and old legacy cookies must fail authorization.

A02 - Fixed: Staff can write into any known or invented upload staging ID

Severity: High. Source: server/src/uploadStore.js:36.

Upload IDs have persistent owners. Staff, unknown IDs, expired uploads and other accounts are refused on init/chunk/finalize. Ownership is retained for unreferenced finalized assets. Existing in-progress uploads must restart.

Acceptance check: Staff writes return 403; a second editor cannot initialize, resume, finalize or delete another editor’s unused upload.

A03 - Fixed: Unpublish then publish cannot restore a scene to live

Severity: High. Source: server/src/store.js:205.

New publication numbers are allocated above all retained history, including after unpublishing. Immutable snapshots are preserved.

Acceptance check: Publish/unpublish/publish repeatedly; every attempt succeeds with a new increasing version, including after restoring older snapshots.

A04 - Fixed: Version restore rolls back scene ownership

Severity: High. Source: server/src/store.js:271.

Restoring history preserves the current owner and project, and updates the editing revision.

Acceptance check: Restore a snapshot after transfer/detach/delete-project flows and assert current ownerId and permissions remain unchanged.

A05 - Fixed: Booking read failures become empty inventory and can destroy records

Severity: High. Source: server/src/reservations.js:28.

Only a missing booking file is empty. Corruption, invalid record shape and disk failures fail closed; the original damaged file is preserved.

Acceptance check: Malformed JSON and simulated read failures must return a controlled service error and leave the original file intact.

A06 - Fixed: One-time reset links can be redeemed twice concurrently in file mode

Severity: High. Source: server/src/usersStore-file.js:168.

File-account mutations are serialized. A reset token has one concurrent winner; role/password/reset updates no longer race read-modify-write operations.

Acceptance check: Concurrent redemption has exactly one success. Concurrent password reset and role change preserve both the new password and intended role.

A07 - Fixed: Concurrent first signups both become administrators

Severity: Medium. Source: server/src/usersStore-pg.js:57.

File bootstrap is serialized and checks physical account files before declaring an empty store. PostgreSQL uses a transactional advisory lock for first signup. PostgreSQL implementation is source-reviewed; real database execution remains pending.

Acceptance check: Concurrent initial registration creates at most one admin; staff invitation must never unexpectedly become admin.

A08 - Fixed: Public enquiries accept nonexistent or unpublished scene references

Severity: Medium. Source: server/src/routes/leads.js:15.

Enquiries require a published scene or a real project hub. Unknown/draft scene requests return 404 instead of creating orphan leads. Project routing comes from the published scene.

Acceptance check: Unknown/draft scenes cannot create leads; published tours route enquiries to the project shown to visitors.

A09 - Fixed: Corrupt website state is silently treated as a new website

Severity: High. Source: server/src/routes/sites.js:58.

Website read failures propagate rather than returning null and overwriting publication/review/schedule state.

Acceptance check: Invalid JSON yields a controlled error and a draft save cannot replace the damaged state.

A10 - Fixed: External availability response size is checked after full buffering

Severity: Medium. Source: server/src/engine.js:59.

Engine bodies are streamed with a 64 KiB cap and a four-second total timeout; oversized bodies are destroyed before full buffering.

Acceptance check: A response over the cap is aborted before full consumption and peak memory stays bounded under simultaneous requests.

A11 - Fixed: Suffix byte ranges return incorrect file content

Severity: Medium. Source: server/src/routes/assets.js:531.

Suffix byte ranges now return the final N bytes. Empty, zero-length and unsatisfiable ranges are refused.

Acceptance check: Verify bytes=-3, bytes=-100, bytes=3-, bytes=-0, zero-length files and large integer boundaries.

A12 - Fixed: Byte ranges extending past EOF are rejected unnecessarily

Severity: Medium. Source: server/src/routes/assets.js:533.

A satisfiable range extending past EOF is clamped to the last byte rather than rejected.

Acceptance check: Check bytes=0-99 returns the complete 10-byte file as 206, while bytes=10-99 returns 416.

A13 - Fixed: Booking dates are validated by shape rather than calendar validity

Severity: Medium. Source: server/src/calendar.js:2.

Server booking entry points require a strict calendar round trip, including leap years. Invalid dates cannot reach the night generator.

Acceptance check: Reject November 31, February 30, month 00/13 and day 00; accept valid leap days and enforce date windows.

A14 - Fixed: One bad scene can break the entire studio scene list

Severity: Medium. Source: server/src/records.js:4.

Malformed listing records are logged and isolated from healthy scene/account/lead listings. Public gallery reads likewise isolate corrupt scene JSON. Damaged individual records still require operator recovery.

Acceptance check: One bad record is detected and alerted without taking unrelated accounts, projects or public listings offline.

A15 - Mitigated: Website and hotspot bookings do not share room/hall inventory

Severity: High. Source: server/src/routes/reservations.js:405.

One booking channel per room/hall resource kind is enforced. Hotspot requests/marks are refused while website booking is enabled. Publishing/scheduling a switch is blocked by active legacy hotspot bookings; live website guest requests also refuse legacy conflicts. Resource IDs have not been unified; reconcile existing bookings before switching.

Acceptance check: Booking through either channel blocks overlapping requests/confirmations/marks through the other.

A16 - Mitigated: Multiple API processes bypass in-memory booking locks

Severity: High. Source: server/src/processLock.js:6.

Production refuses another API writer for the same DATA_DIR. PM2 configuration uses one instance and fixed loopback ports. This enforces the supported single-process architecture; it does not implement multi-node transactions or shared distributed rate limits.

Acceptance check: Run a two-process last-table contention test after the storage fix; exactly one reservation succeeds and no records disappear.

A17 - Fixed: Concurrent project/scene/site updates can lose edits and permission changes

Severity: High. Source: server/src/serial.js:7.

Metadata mutations and website scheduling are serialized. Full scene and website edits carry revisions and stale edits return 409. Upload operations use a separate queue so model finalization does not hold the metadata queue. Multi-file crash consistency still depends on recovery/backups; this is not a database migration.

Acceptance check: Race publish/save, membership changes, claims and scheduled publish; all intended updates survive or receive explicit conflicts.

A18 - Fixed: Uploads have no total quota, expiry or ZIP expansion budget

Severity: High. Source: server/src/uploadStore.js:9.

Defaults: 8 GiB/upload, 20,000 files, 100 GiB/account for uploads with ownership records, 20 active uploads/account, 24-hour staging expiry and disk headroom checks. ZIP extraction checks expansion count/bytes/path depth while extracting. Pre-upgrade orphan staging needs reviewed manual cleanup; existing assets without metadata are outside the new quota ledger.

Acceptance check: Small-budget tests stop oversized uploads safely, remove partial extraction, and leave capacity for normal bookings.

A19 - Fixed: Concurrent chunks can overwrite each other after the offset check

Severity: Medium. Source: server/src/uploadStore.js:51.

Chunks/finalization are serialized with an ownership recheck inside the queue. Same-offset concurrent chunks yield one success and one conflict.

Acceptance check: Two same-offset chunks produce one accepted write and one conflict; finalize cannot race an unfinished chunk.

A20 - Fixed: Engine URL filtering does not prevent DNS-based private network access

Severity: Medium. Source: server/src/engine.js:42.

Production engine hosts require an explicit allowlist and HTTPS/443. DNS is validated in the socket lookup and the connection uses the validated result; private, loopback and link-local addresses are refused. Redirects are not followed. Configure vetted adapter hosts before enabling real integrations.

Acceptance check: A controlled hostname resolving to loopback/private/link-local addresses is refused without initiating the connection.

A21 - Fixed: Public room availability can trigger uncapped engine requests

Severity: Medium. Source: server/src/engine.js:93.

Availability reads are rate limited; external engine work has a four-request concurrency cap, in-flight deduplication, bounded input and failure caching.

Acceptance check: A local fake engine sees bounded requests under a flood of varied dates; healthy callers still receive timely responses.

A22 - Fixed: Attachment upload consumes its one-time key before saving the file

Severity: Medium. Source: server/src/routes/reservations.js:697.

Attachment file storage succeeds before consuming the one-time key. A simulated storage failure preserves the key and a retry succeeds. Private attachment metadata is committed in the booking queue.

Acceptance check: Inject a storage failure: the guest can retry with the original key and the inbox does not show a nonexistent attachment.

A23 - Prepared: The backup command does not back up PostgreSQL accounts or external local assets

Severity: High. Source: server/scripts/backup-data.js:56.

Backup format 2 includes JSON, external local assets and optional PostgreSQL app-schema dump plus a manifest. JSON and external asset restore passed locally. Real PostgreSQL restore, bucket backup/versioning, secured secret backup and off-VPS recovery still need deployment verification. Archive format changed: use deploy/README.md restore steps.

Acceptance check: Restore into an empty machine/database; confirm accounts, permissions, booking history, attachments, scene JSON and every scan all work.

A24 - Prepared: VPS deployment files are absent and production defaults are permissive

Severity: High. Source: deploy/README.md:1.

Added nginx/TLS starter configuration, one-instance PM2 setup, environment example and restore instructions. Production API binds loopback by default, enforces HTTPS CLIENT_ORIGIN, refuses example secrets and fails on port conflicts. Actual VPS provisioning, nginx validation, DNS/certificates/firewall and account-level settings have not been performed.

Acceptance check: Test from an external machine: only intended HTTPS ports are open, cookies are secure, API routing works, restarts retain data, and a port conflict fails visibly.

A25 - Fixed: Some Express 4 async authentication handlers do not forward rejected promises

Severity: Medium. Source: server/src/middleware/auth.js:79.

Async admin and session handlers catch lookup failures and forward to Express error handling. Fault-injection checks receive controlled 500 responses without terminating the API.

Acceptance check: Force account lookup to reject and assert a sanitized 5xx response, no hung request, and continued API health.

A26 - Fixed: Server lockfile includes a qs version flagged by npm audit

Severity: Medium. Source: server/package-lock.json:881.

Updated the compatible server qs dependency. npm audit fix reported zero vulnerabilities after the update; the lockfile is changed. No forced major upgrades were applied.

Acceptance check: Server audit has no remaining advisory and query parsing/API regressions still pass. Source: https://github.com/advisories/GHSA-6pq8-jhm2-2vcw

A27 - Fixed: Private booking attachments are missing from git ignore rules

Severity: Medium. Source: .gitignore:46.

Private attachments, ownership records and the default API lock are now ignored by git. Production runtime data is configured outside the code checkout.

Acceptance check: git check-ignore confirms a sample default-path attachment is ignored; no guest files are tracked.

A28 - Fixed: Tour defaults assume Nepal even when the venue uses another timezone

Severity: Medium. Source: src/features/booking/HotspotBookCard.tsx:72.

Hotspot booking reads the configured venue timezone from a public clock endpoint and uses it for date defaults/minimums and outgoing booking links. Submission waits for the clock.

Acceptance check: Check venues in Kathmandu, Honolulu and Auckland around midnight with visitors in different timezones.

A29 - Fixed: Tour first render waits for every published scene in the project

Severity: Medium. Source: src/app/tour/TourClient.tsx:77.

The public tour loads the starting document first; sibling documents load on selection. API fetches have bounded timeouts and superseded scene loads are ignored. Production build/type checks pass; first-frame and motion performance still need real GPU/mobile measurements.

Acceptance check: With one sibling scene delayed or failed, the requested healthy scene still opens within the first-frame target on a real mobile device.

A30 - Open: Public marketing content still contains editorial placeholders

Severity: Low. Source: src/features/marketing/pages/GameWorldsPage.tsx:50.

Business facts and policy placeholders require verified owner content. No company details, licensing promises or legal policy wording were invented. Review rendered public pages before launch.

Acceptance check: Crawl rendered public pages for TBI/TBC, broken contact actions and draft content before launch.